SECCIÓN 5.6

Correlación de eventos y construcción de contexto

Temas de esta sección:

- Qué significa correlacionar eventos (no solo juntar datos)
- La línea temporal: cómo construirla y para qué sirve
- Correlación endpoint + correo, + red, + DNS, + identidad, + WAF
- Correlación entre hosts: el mismo patrón en múltiples equipos
- Señales que aumentan y reducen sospecha
- Hipótesis fuerte vs hipótesis débil
- Cómo documentar una correlación

5.6 | La línea temporal: de eventos sueltos a hipótesis

Correlacionar no es solo juntar datos. Es buscar relaciones útiles para construir contexto y tomar decisiones:

09:58	**Email Gateway**	Adjunto recibido: Factura_Junio.docm | Sender: facturacion@external.com
10:01	**EDR**	WINWORD.EXE abrió el documento
10:02	**EDR**	WINWORD.EXE → powershell.exe -nop -w hidden -enc <base64>
10:03	**DNS**	Query: files-check-update.net → 185.22.14.90
10:04	**Firewall**	Connection: 185.22.14.90:443 Allowed
10:05	**EDR**	File created: C:\Users\Public\update.exe (por powershell.exe)
10:06	**EDR**	update.exe ejecutado + scheduled task creado
10:08	**Firewall**	update.exe → sync-check-cloud.net cada 60 segundos

5.6 | Correlación multi-fuente: endpoint + correo + red + identidad + WAF

Cada fuente aporta una perspectiva. La correlación las une para construir la imagen completa:

EMAIL GATEWAY

Aporta: Adjuntos recibidos · Remitente · Asunto · Hora · Receptor · Si fue abierto

Preguntar: ¿Hubo un correo que inició la cadena? ¿Otros usuarios recibieron el mismo?

EDR

Aporta: Proceso, padre, línea de comandos, archivos, ruta, firma, hash, conexiones

Preguntar: La fuente más rica para análisis de endpoint. Central para cualquier alerta de proceso.

FIREWALL / PROXY

Aporta: Conexiones, IP destino, puerto, acción, volumen, frecuencia

Preguntar: ¿La conexión fue permitida? ¿Qué destino? ¿Hay patrones de beaconing?

DNS

Aporta: Dominios consultados, respuestas, NXDOMAIN, frecuencia, primer visto

Preguntar: ¿Qué intentó resolver? ¿Dominios nuevos? ¿DGA? ¿Coincide con actividad de proceso?

IDENTIDAD / IAM

Aporta: Login, MFA, dispositivo, ubicación, reglas, OAuth apps, acceso a apps

Preguntar: ¿Hay actividad inusual de cuenta? ¿El login precede la actividad técnica?

WAF / APP LOGS

Aporta: Requests HTTP, payloads, respuestas, endpoints accedidos, user-agents

Preguntar: ¿Hubo intento de explotación web? ¿El payload fue procesado (200) o bloqueado?

5.6 | Correlación entre hosts: el mismo patrón en múltiples equipos

Un indicador en un host puede ser ruido. El mismo indicador en múltiples hosts cambia el análisis:

```
# Búsqueda de alcance: mismo hash en otros endpoints
Sha256: a3f4c9e2... (update.exe de FIN-LAP-022)

Resultados:
  FIN-LAP-022    → ALERTA ORIGINAL  | Ejecutado | Scheduled task creada
  HR-LAP-044     → Hash encontrado  | Ejecutado | Conexiones externas detectadas
  LEGAL-LAP-011 → Hash encontrado  | No ejecutado | En carpeta Downloads
  SALES-LAP-088 → Hash encontrado  | Ejecutado | Tarea creada el día anterior

  4 hosts afectados. 3 con ejecución confirmada. 1 sin ejecución (ventana aún activa).
```

Qué cambia cuando hay múltiples hosts:

▸ Aumenta la urgencia

El alcance ya no es un endpoint aislado. Puede indicar campaña activa.

▸ Cambia el escalamiento

Múltiples hosts requiere IR, no solo análisis individual.

▸ Define el origen

El host con la fecha más antigua puede ser el primer infectado.

▸ Amplía la preservación

Hay que preservar evidencia en todos los hosts antes de contener.

5.6 | Señales que aumentan y reducen sospecha

Al correlacionar, algunas señales cambian la prioridad del caso:

⬆ Señales que AUMENTAN sospecha	⬇ Señales que REDUCEN sospecha
▸ Proceso padre inusual (Office, Outlook)	▸ Ticket aprobado y coincide con actividad
▸ Usuario no técnico con herramientas admin	▸ Ventana de mantenimiento activa
▸ Ruta sospechosa (Public, Temp, AppData)	▸ Usuario técnico esperado
▸ Archivo no firmado o hash desconocido	▸ Script en ruta corporativa firmado
▸ Conexión periódica externa	▸ Binario firmado por proveedor conocido
▸ Persistencia creada	▸ Destino corporativo conocido
▸ Movimiento lateral o múltiples hosts	▸ Dispositivo y ubicación habituales
▸ Cuenta privilegiada involucrada	▸ Bloqueo efectivo sin actividad posterior
▸ Regla de correo externa creada	▸ Comportamiento histórico habitual
▸ Transferencia de alto volumen	▸ Confirmación del dueño del sistema
▸ Actividad fuera de horario	▸ Scanner autorizado activo

5.6 | Hipótesis fuerte vs hipótesis débil

La hipótesis debe reflejar exactamente la evidencia disponible — ni más, ni menos:

PowerShell ejecutado. Puede ser malware.	Se observó powershell.exe iniciado por WINWORD.EXE con parámetros -nop, -w hidden y -enc. El usuario pertenece a Finanzas y no se identificó contexto administrativo. La secuencia es compatible con posible ejecución inicial mediante documento.
Hay C2.	Se observa svcupdate.exe en C:\Users\Public\ generando conexiones HTTPS cada 60 segundos hacia sync-check-cloud.net. El archivo fue creado por powershell.exe y hay una tarea programada asociada. El patrón es compatible con posible comunicación externa automatizada.
El usuario filtró datos.	Se observó transferencia de 4.8 GB hacia drive.google.com. No se pudo confirmar si la cuenta destino es corporativa o personal. Se requiere validación del usuario y revisión de actividad previa antes de confirmar o descartar.

5.6 | Cómo documentar una correlación

Una correlación bien documentada permite que quien reciba el caso entienda sin empezar de cero:

FUENTES REVISADAS	Indicar qué herramientas y rangos de tiempo se consultaron. Ejemplo: EDR (FIN-LAP-022, últimas 4h), SIEM (logs DNS y firewall 09:00-11:00), Email Gateway (bandeja de finanzas.paz).
LÍNEA TEMPORAL	Listar los eventos en orden cronológico con fuente, timestamp y descripción. Formato: 10:02 | EDR | WINWORD.EXE → powershell.exe -enc. Incluir solo eventos relevantes, no todos los logs.
HIPÓTESIS	Plantear la interpretación con el nivel de certeza correspondiente. Usar lenguaje como: 'compatible con', 'sugiere posible', 'no se pudo confirmar'. No afirmar sin evidencia directa.
LIMITACIONES	Documentar qué no se pudo revisar: 'No se dispone de visibilidad EDR en el servidor', 'No se pudo validar correo origen', 'Hash pendiente de análisis'. Las limitaciones son parte del análisis.
DECISIÓN Y PRÓXIMO PASO	Indicar la acción tomada y por qué: escalar, cerrar, monitorear o pedir validación. Incluir qué se necesita para avanzar: 'Pendiente: revisión del correo origen y búsqueda del hash en otros hosts'.